Capstone Project

Designing a Mid-sized Enterprise Network

Masterschool (MSIT)

by Ruben Faude

Directory

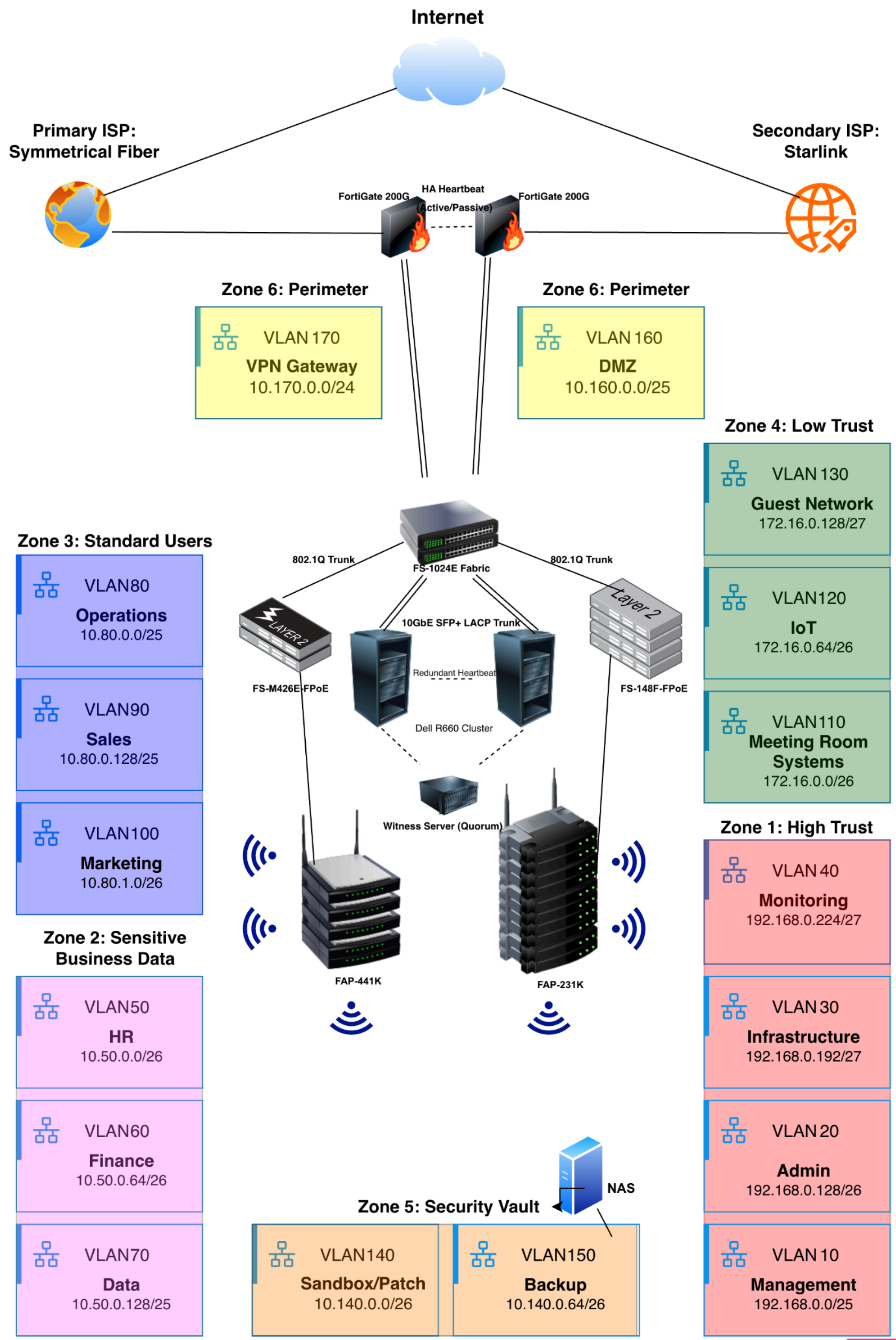
Requirements

Category	Key Requirements	Technical Targets & Constraints
Scale & Growth	90 Employees -> 120 (1 year)	Support 150–180 devices (Laptops, VoIP, IoT).
Connectivity	Hybrid & Remote Support	40% Remote; Seamless AP coverage; VPN for all.
Performance	Traffic Prioritization	High Priority: VoIP & Video; Peak Drivers: AI & Cloud.
Segmentation	Tiered Network Access	Isolated zones: Finance, HR, Guests, Contractors.
Security	Identity & Compliance	RBAC Mandatory; MFA; GDPR & ISO 27001 alignment.
Device Management	CYOD / COPE / BYOD	Implementation of MDM; clear BYOD/COPE distinction.
Availability	Multi-Tiered Uptime	99.9% for revenue-critical; <60m total company tolerance.
Budget	Cost-Effective Resilience	Build: €80k–200k; Ops: ~€450k/year (typical baseline).
Availability & Recovery	Multi-Tiered Uptime & RTO Tiers	99.9% Uptime (critical); <60m total tolerance. **RTOs:** 5-15m (Revenue/Sec); 10-30m (Finance); 30-60m (Ops); 1-2h (HR).

Framework

I chose the NIST CSF (National Institute of Standards and Technology - Cybersecurity Framework v2.0) as a guiding framework because my task is to design a medium-sized enterprise network. The NIST CSF is defender-centric, meaning that the construction of a resilient and defensible network is central to this framework. Although MITRE ATT&CK is a good complement to NIST CSF for a holistic perspective on cybersecurity and secure network design, the NIST CSF is more focused on defensive capabilities rather than offensive TTPs. That is why I chose this framework: it provides more orientation guidelines for constructing a network. The core of this framework is the standardized split into the following actionable steps, applicable to most, if not all, network designs:
Govern: Establish the organization’s cybersecurity strategy and oversight;
Identify: Understand your assets, risks, and data;
Protect: Implement safeguards to ensure delivery of services;
Detect: Develop activities to identify the occurrence of a cybersecurity event;
Respond: Take action once a detected event occurs;
Recover: Restore capabilities or services that were impaired.
By following these steps in network design, a strong security foundation is built. With the focus on the current profile and the prospective target profile, network engineers can easily identify the gaps between the current state and the desired security posture. Providing four tiers of cybersecurity adaptation and workflow implementation, companies can find out how well they are equipped to deal with security-related risks. By prioritizing supply chain risks and established B2B trust relationships, another layer of holistic network design is accomplished. Focusing on target outcomes, the NIST CSF is vendor-agnostic, meaning as long as a certain outcome is provided, it does not care about the manufacturer of hardware/software assets. All these different aspects allow for flexible security implementation, dynamic assessment and prospective optimization. In summary, the NIST CSF not only provides selective security mechanisms but also offers a holistic approach to constructing and securing a network with a significant focus on sustainability and prospective adaptations.

Logical Topology Diagram



IP Addressing Scheme & Network Segmentation

The following table outlines the comprehensive network architecture, including logical Proof-of-Concept (PoC) addressing and practical production IP mapping across all 17 VLANs and 6 security zones.

Network Architecture & Addressing Rationale:

Dual-Scheme Strategy: Combines logical PoC and optimized production schemes for SOC efficiency.
Operational Awareness: Diverse IP classes allow analysts to instantly map prefixes to VLANs without overhead.
Performance: FortiGate ensures seamless routing; lack of route summarization is negligible at this scale.
DMZ (VLAN 160): Uses /25 for spoofing defense, honeypots, and HA VIPs, preserving /24 block integrity.
VLAN 30: Restricted /27 hosts auth servers to prevent lateral movement from user traffic.
Security Footprint: Minimal subnet sizes act as proactive controls to isolate mission-critical infrastructure.
VLAN 100 (Marketing): Uses 10.80.1.0/26 to ensure 'Standard User' zone (10.80.x.x) consistency.
Categorization: Prioritizes functional grouping over numerical IDs for instant SOC identification.
IoT (Zone 3): Groups low-trust assets in VLAN 120 for simplified, centralized policy management.
Security: Maintains robust protection through strict VLAN-level isolation and restricted service access.
Scalable Grouping: User VLANs span multiple subnets for capacity while maintaining logical grouping.
BYOD Policy: Relegates all BYOD assets to the Guest Network (VLAN 130) to neutralize unmanaged device risks.
Traffic Prioritization: Employs a robust QoS framework to prioritize traffic based on operational criticality.
Latency: VLAN 110 (Meetings) and 90 (Sales) get priority queuing for real-time collaboration.
Throughput: Optimizes VLAN 70 (Analytics) for processing without impacting critical channels.
Scannability: Prevents fragmentation by keeping tables on single pages for better readability.
Routing: L3 switching for high-volume traffic (VLAN 150) offloads the FortiGate to prioritize inspection of security-critical zones.
SD-WAN: Performance SLAs dynamically steer latency-sensitive traffic (VoIP) between fiber and Starlink to guarantee QoS.

VLAN	Inventory & Capacity	Logical Addressing (PoC)	Practical Addressing	Security & Performance Needs	Access Control
10 Management Zone 1: High Trust	Core/Access Switches, NGFWs, APs MGMT, WLCs Total: ~31-64 Growth buffer: +20% Endpoints: ~40-80	SM: 192.168.0.0/25 NA: 192.168.0.0 GW:192.168.0.1 BC: 192.168.0.127 Usable IPs: 126	*Same as Logical*	High Security Low Bandwidth, High Availability, Restricted Access	In: Admin (VLAN 20) only Out: Restricted
20 IT/Admin Zone 1: High Trust	Admin Devices Total: ~6-15 Growth buffer: +40% Endpoints: ~9-21	SM: 192.168.0.128/26 NA: 192.168.0.128 GW:192.168.0.129 BC: 192.168.0.191 Usable IPs: 62	*Same as Logical*	Very High Security Admin Control; Moderate Bandwidth, High Availability	In: None Out: Management (VLAN 10), Logging (VLAN 40) Infrastructure (VLAN 30), Controlled access to all other VLANs for administration
30 Critical Infrastructure/ System Authentication Zone 1: High Trust	Total: ~7-14 Growth buffer: +50% Endpoints: ~10-20	SM:192.168.0.192/27 NA: 192.168.0.192 GW:192.168.0.193 BC: 192.168.0.223 Usable IPs: 30	*Same as Logical*	High Security Low Bandwidth usage, Mission-Critical Availability and Latency Sensitivity	Accessible from all user VLANs (authentication, DNS, etc.) Cannot initiate connections to user VLANs

40 Logging/ Monitoring Zone 1: High Trust	Total: ~5-8 Growth buffer: ~30% Endpoints: ~8-16	SM: 192.168.0.224/27 NA: 192.168.0.224 GW:192.168.0.225 BC: 192.168.0.255 Usable IPs: 30	*Same as Logical*	High Security Continuous Operation, High Integrity and Auditability required	✔ Receives logs from all VLANs ✔ Accessible only from IT/Admin ❌ No direct access to user systems
50 HR Zone 2: Sensitive business data	User Laptops Total: ~4-10 Growth buffer: +40% Endpoints: ~6-14	SM: 192.168.1.0/26 NA: 192.168.1.0 GW:192.168.1.1 BC: 192.168.1.63 Usable IPs:62	SM: 10.50.0.0/26 NA: 10.50.0.0 GW:10.50.0.1 BC: 10.50.0.63 Usable IPs: 62	High Security Low-Moderate Bandwidth	✔ Access to required shared services only ✔ Strong restrictions on inbound access
60 Finance Zone 2: Sensitive business data	User Laptops Total: ~6-16 Growth buffer: +25% Endpoints: ~8-20	SM: 192.168.1.64/26 NA: 192.168.1.64 GW:192.168.1.65 BC: 192.168.1.127 Usable IPs: 62	SM: 10.50.0.64/26 NA: 10.50.0.64 GW:10.50.0.65 BC: 10.50.0.127 Usable IPs: 62	High Security Moderate Bandwidth High Availability	✔ Access to required shared services only ✔ Strong restrictions on inbound access
70 Data Zone 2: Sensitive business data	Analytics PCs Total: ~16-40 Growth buffer: +100% Endpoints: ~32-80	SM: 192.168.1.128/25 NA: 192.168.1.128 GW:192.168.1.129 BC: 192.168.1.255 Usable IPs: 126	SM: 10.50.0.128/25 NA: 10.50.0.128 GW:10.50.0.129 BC: 10.50.0.255 Usable IPs: 126	High Security High Bandwidth Low Latency	✔ Access to required shared services only ✔ Strong restrictions on inbound access
80 Ops Zone 3: Standard users	Standard Laptops Total: ~25-60 Growth buffer: 20% Endpoints: ~30-72	SM: 192.168.2.0/25 NA: 192.168.2.0 GW:192.168.2.1 BC: 192.168.2.127 Usable IPs: 126	SM: 10.80.0.0/25 NA: 10.80.0.0 GW:10.80.0.1 BC: 10.80.0.127 Usable IPs: 126	Standard Security Moderate Performance	✔ Internet access ✔ Access to shared/internal services ❌ No direct access to sensitive VLANs (HR, Finance)
90 Sales Zone 3: Standard users	Mobile Devices Total: ~40-74 Growth buffer: +30% Endpoints: ~60-100	SM: 192.168.2.128/25 NA: 192.168.2.128 GW:192.168.2.129 BC: 192.168.2.255 Usable IPs: 126	SM: 10.80.0.128/25 NA: 10.80.0.128 GW:10.80.0.129 BC: 10.80.0.255 Usable IPs: 126	Standard User Access High Priority traffic class	✔ Internet access ✔ Access to shared/internal services ❌ No direct access to sensitive VLANs (HR, Finance)
100 Marketing Zone 3: Standard users	Workstations Total: ~20-45 Growth buffer: +30% Endpoints: ~27-60	SM: 192.168.3.0/26 NA: 192.168.3.0 GW:192.168.3.1 BC: 192.168.3.63 Usable IPs: 62	SM: 10.80.1.0/26 NA: 10.80.1.0 GW:10.80.1.1 BC: 10.80.1.63 Usable IPs: 62	Moderate Security High Performance	✔ Internet access ✔ Access to shared/internal services ❌ No direct access to sensitive VLANs
110 Meeting Room Systems Zone 4: Low trust	Standard Laptops Total: ~15-25 Growth buffer: +20% Endpoints: ~18-30	SM: 192.168.4.0/26 NA: 192.168.4.0 GW:192.168.4.1 BC: 192.168.4.63 Usable IPs: 62	SM: 172.16.0.0/26 NA: 172.16.0.0 GW:172.16.0.1 BC: 172.16.0.63 Usable IPs: 62	Moderate security High Bandwidth Requirements, High Reliability, Latency-Sensitive (real-time communication)	✔internet ✔ collaboration services ❌ No access to sensitive internal systems
120 IoT/ networked Printers Zone 4: Low trust	Mobile Devices Total: ~10-20 Growth buffer: +20% Endpoints: ~12-24	SM: 192.168.4.64/26 NA: 192.168.4.64 GW:192.168.4.65 BC: 192.168.4.127 Usable IPs: 62	SM: 172.16.0.64/26 NA: 172.16.0.64 GW:172.16.0.65 BC: 172.16.0.127 Usable IPs: 62	High Security Low Bandwidth, High Reliability	❌ No access to internal VLANs ✔ Only allowed to: required services (e.g., print servers) ❌ No inbound connections allowed
130 Guest Network Zone 4:	Workstations Total: ~5-10 Growth buffer: +100% Endpoints: ~10-20	SM: 192.168.4.128/27 NA: 192.168.4.128 GW:192.168.4.129 BC: 192.168.4.159	SM: 172.16.0.128/27 NA: 172.16.0.128 GW:172.16.0.129	Security: isolated Low-Moderate	❌ No internal access at all ✔ Internet only

Low trust		Usable IPs: 30	BC: 172.16.0.159 Usable IPs: 30	performance	
140 Sandbox/ Patch testing Zone 5: Security Vault	Test Systems/Clones Total: ~5-10 + 30 temporary clones Growth buffer: +50% Endpoints: ~45-60	SM: 192.168.5.0/26 NA: 192.168.5.0 GW:192.168.5.1 BC: 192.168.5.63 Usable IPs: 62	SM: 10.140.0.0/26 NA: 10.140.0.0 GW:10.140.0.1 BC: 10.140.0.63 Usable IPs: 62	Absolute Isolation Low baseline; Moderate during patch cycles	✔ In: Admin (VLAN 20) via SSH/RDP/Proxmox only ✔ Out (Ext): Updates via Proxy only X Out (Int): Total Internal Isolation
150 Backup Zone 5: Security Vault	Immutable Repositories Total: ~3.5 Growth buffer: +20% Endpoints: ~5-7	SM: 192.168.5.64/26 NA: 192.168.5.64 GW:192.168.5.65 BC: 192.168.5.127 Usable IPs: 62	SM: 10.140.0.64/26 NA: 10.140.0.64 GW:10.140.0.65 BC: 10.140.0.127 Usable IPs: 62	Maximum Security, immutable High Throughput	✔ In: Specific backup ports & Admin (VLAN 20) Jump-Host ❌ Out: No initiated connections (except Updates) ❌Internet: Strictly Blocked
160 DMZ Zone 6: Perimeter	Public Facing Services Total: ~10-15 Growth buffer: +100% Endpoints: ~30	SM: 192.168.5.128/25 NA: 192.168.5.128 GW:192.168.5.129 BC: 192.168.5.255 Usable IPs: 126	SM: 10.160.0.0/25 NA: 10.160.0.0 GW:10.160.0.1 BC: 10.160.0.127 Usable IPs: 126	Untrusted Zone Moderate to High Performance	✔ WAN In: Restricted (TCP 25, 443) ✔ Mgmt: Inbound from Admin (VLAN 20) only ❌Internal: Blocked (except Mail/Proxy to VLAN 30)
170 VPN Gateway Zone 6: Perimeter	Remote Clients Total: ~35-90 Growth buffer: +30% Endpoints: ~50-120	SM: 192.168.6.0/24 NA: 192.168.6.0 GW:192.168.6.1 BC: 192.168.6.255 Usable IPs: 254	SM: 10.170.0.0/24 NA: 10.170.0.0 GW:10.170.0.1 BC: 10.170.0.255 Usable IPs: 254	Identity based Security High Performance Needs	✔ WAN In: Encrypted Tunnels (UDP 443/4500) only ✔ Internet: Forced Tunneling via Security Stack ✔ Internal: Restricted to VLAN 30 (Services/Wiki) ❌Lateral: No access to Client, Mgmt, or Backup VLANs

Network Fabric & Perimeter Security

Core Design: Collapsed Core (Single Pane for easier MGMT) via Active/Passive FortiGate 200G cluster, VPN and Fortiguard UTP..
Switching: FS-1024E fabric with MCLAG redundancy and FortiRPS power.
Tiered Wireless: FAP-441K for high-density zones; FAP-231K for general office coverage.
Dual WAN: Symmetrical Fiber plus Starlink backup ensures uninterrupted internet access.
Compute HA: 2-node cluster (R660/DL360) with Witness Server for quorum integrity.
Backup Strategy: Enforces 3-2-1 rule via 10-GbE local NAS and encrypted Cloud repositories.
Physical Standards: Future-proofed Cat 6a cabling supporting 10Gbps rates enterprise-wide.

Compute Architecture & System Resilience

2-Node HA Cluster: Dual enterprise nodes (R660/DL360) + Witness NUC for quorum.
Physical Resilience: Split-room deployment with independent power circuits.
Redundant Heartbeat: Dual links via primary fabric and direct-connect cables.
Modular Isolation: Minimizes failure domains by localizing errors across independent VMs.
Hybrid Identity: Integrates Open Source "islands" into AD via LDAP/SAML for unified management.
Full-Stack Visibility: Centralized Zabbix monitoring and Wiki-based "Single Source of Truth".
Cost Optimization: Uses open-source to reduce licensing overhead; reinvests savings in training.
Seamless Growth: Scalable architecture allows for easy integration of additional nodes with minimal reconfiguration.

Inventory

Network Tier / Role	Hardware Model & Options	Quantity & Deployment Details	Estimated Unit Price (USD)
Core Switching	**Fortinet FS-1024E**	**2 (Stacked)** Connected via SFP+ Direct Attach Copper (DAC) or SFP+ Multimode Optics.	FS-1024E: ~$14,995 DAC Cables: ~$90 - $150
Access Switching (Marketing Dept)	**Fortinet FS-M426E-FPoE**	**2 (Stacked)** Uplinks to Core A and B via MC-LAG.	~$3,166 - $4,200
Access Switching (Basic Office)	**Fortinet FS-148F-FPoE**	**4** Uplinks to Core A and B via MC-LAG.	~$1,484 - $2,600
Edge Security (NGFW)	**Fortinet FortiGate 200G**	**2 (Active/Passive HA)** • Handles VPN routing. • Redundant connections to core switches. • Requires FortiGuard UTP license.	Hardware: ~$6,200 - $7,920 UTP License: Varies by term/duration
Wireless LAN (WLAN)	**High Perf: Fortinet FAP-441K** **Mod Perf: Fortinet FAP-231K**	**5 Total FAP-441K + 10 FAP-231K** • Distributed for seamless roaming and coverage.	FAP-441K: ~$1,395 FAP-231K: ~$490 - $590
Redundant Power	**Core: Redundant PSUs** **Access: Fortinet FortiRPS 100**	**2x FortiRPS 100** • Supplies backup power to the access switch stacks.	FortiRPS 100: ~$600 - $694
Compute Servers (Hypervisor Cluster)	**Dell PowerEdge R660 or HPE ProLiant DL360**	**2 (Clustered)** • Primary connection via switches. • Secondary direct connection (Heartbeat). • Separated physically/different power circuits.	~$8,000 - $15,000+ (Highly dependent on CPU, RAM, and storage config)
Compute Server (Quorum / Witness)	**Intel NUC 13 Pro (or similar)**	**1** - Acts as a tie-breaking witness node for the 2-node VM cluster.	~$500 - $700
Backup Storage (On-Premises)	**Synology Enterprise NAS or Veeam on Dell hardware**	**1** - Equipped with 10-GbE Network Interface Cards (NICs).	Synology NAS: ~$2,500 - $6,000+ (Chassis only, drives extra)
Backup Storage (Off-Site)	**Cloud Backup Target**	**1**	Subscription based
WAN / ISP Links	**1. Symmetrical Fiber** **2. Starlink Kit or Copper**	**2** - Redundant provider lines for failover.	Starlink Hardware: ~$599 Monthly ISP Fees: Varies
Physical Infrastructure	**Server Racks** **Cat 6a Patch Cables**	**Standard 42U Racks** • Cat 6a specified for all copper runs.	Racks: ~$800 - $1,500 Cabling: ~$2 - $10 / patch
Total Estimated Cost			100.000 - 170.000$

Server Clustering

System / VM Name	VLAN	System Type	Services & Roles	Resilience & Placement Logic
PVE-MGMT	**10**	**Hypervisor**	Proxmox Management Interface	True Control Plane. Strict access only from VLAN 20. Needs DPI bypass.
FGT-MGMT	**10**	**Appliance**	Fortigate Management	Core network management. Isolated from all user traffic.

DC-01	**30**	**Win Server**	AD, DNS, NTP, DHCP, LAPS	Host A. Primary identity & DHCP role.
DC-02	**30**	**Win Server**	AD, DNS, NTP, DHCP, LAPS	Host B. Secondary identity. Runs DHCP Failover with DC-01.
SRV-MGMT	**30**	**Win Server**	WSUS, Print, MDM, PXE/Imaging	Central lifecycle management. PXE points here via DHCP Relay.
SRV-DATA	**30**	**Win Server**	SMB / Filesharing	High-performance storage for Internal Ops.
SRV-SEC	**40**	**Win / App.**	EDR & AV Console, FortiAnalyzer	Secure Logging; No outbound to user VLANs.
SANDBOX-01	**140**	**Win 10/11**	Patch & Software Testing	Isolated testing; Non-domain joined.
Cloud Backup	**150**	**150**	Agent/Appliance	Immutable backup zone; high throughput to WAN.
SRV-EDGE	**160**	**Win Server**	Email DLP, SASE Connector	DMZ Service Area. Handles external traffic.
VPN-POOL	**170**	**Network**	Remote User Endpoints	Client Landing Zone. Identity-based access.

Ongoing Licenses

Category	**Product/ License Type**	**1-Year OPEX (Licenses & Support)**	**3-Year OPEX (Licenses & Support)**	**FortiCare / Support Level**	**Service Details**
Hypervisor	**Proxmox VE "Basic"**	$1,400	$3,780	Proxmox Basic Support	4 CPUs (2 per Host). Includes access to Enterprise Repo & Technical Support.
OS (Windows)	**Windows Server 2022 Std. (16-Core)**	$6,000	$5,400	CSP / Partner Support	6 Licenses total. 3-year price is for CSP-Subscription (includes version updates).
Firewall	**FortiGate 200G + UTP Bundle**	$6,500	$9,500	24x7 Adv. HW Replacement	Includes Hardware. FortiCare is bundled with the UTP security subscription.
Core Network	**2x FortiSwitch 1000 Series + FortiCare 24x7 Bundle**	$4,500	$5,800	24x7 NBD Replacement	Core Switch Pair (MCLAG). Support ensures the "heart" of the network is covered.
Logging	**FortiAnalyzer VM (Base)**	$1,500	$1,500	Standard Technical Support	One-time Perpetual License. Support for firmware/troubleshooting is included.
Identity/Users	**M365 Business Premium**	$26,400	$71,280	Microsoft 24x7 Business	100 Users. Includes Entra ID P1, Intune, and high-level tenant support.
Endpoints	**FortiEDR / ZTNA**	$6,000	$14,400	FortiCare 24x7 (SaaS)	100 Endpoints. Cloud-based management and 24x7 threat response support.

Backup	**Cloud Backup (Veeam/Agent)**	$1,080	$2,900	24x7 Production Support	For 6 Windows VMs. Essential for recovery during critical data loss events.
GRAND TOTAL		**$48,880**	**$108,760**		**Yearly Avg (3yr plan): $38,186**

Open-Source Services

VM Name	VLAN	System Type	Services & Roles	Resilience & Placement Logic
VM-ADMIN-01	**20**	**Linux (Debian)**	NetBox (IPAM), Snipe-IT (Assets), IaC Scripts	**IT Core**. Logic: Centralizes "Truth" (IPs/Assets). Use Cron for non-business hour IaC.
VM-JUMP-01	**20**	**Linux (Ubuntu)**	Apache Guacamole, SSH Jump Server	**Admin Entryway**. Multi-Factor Auth (MFA) is mandatory here. Strict logs to VLAN 40.
VM-VAULT-01	**20**	**Linux (Docker)**	Bitwarden (Vaultwarden)	**Secrets.** High-security isolation. Backup to VLAN 150 must be encrypted.
VM-NET-01	**30**	**Linux (Ubuntu)**	FreeRADIUS, Pi-hole, PacketFence	**Gatekeeper.** Sits in Infra. Pi-hole acts as the upstream for Windows DNS.
VM-PKI-01	**30**	**Linux (Java)**	EJBCA (Internal CA)	**Trust Root.** Highly sensitive. Keep off-site backups of the Root Key.
VM-WIKI-01	**30**	**Linux (PHP)**	BookStack	**Knowledge Base.** Needs frequent snapshots; users "read-only" from most VLANs.
VM-MON-01	**40**	**Linux (Docker)**	Zabbix, Grafana, ntopng, Skydive	**Performance.** Visualizes real-time flows. Zabbix monitors ENV sensors & Cameras (VLAN 120).
VM-SIEM-01	**40**	**Linux (Wazuh)**	Wazuh Manager & Dashboard	**Security Brain**. High CPU/RAM. Collects logs from EDR, Windows, and Linux.
VM-SCAN-01	**40**	**Linux (GVM)**	Greenbone (Vulnerability Scanner)	**Audit.** Set to run periodically. Needs high bandwidth during scans.
VM-LNX-TEST	**140**	**Linux**	Linux Sandbox	**Isolation.** Used for testing kernel updates/scripts before production.
VM-BKP-01	**150**	**Linux (Hardened)**	Backup Server & Repository	**Physical Storage.** Needs direct disk pass-through or dedicated ZFS pool.
VM-MAIL-01	**160**	**Appliance**	Proxmox Mail Gateway	**Spam Filter.** Sits in DMZ to scrub mail before it hits SRV-EDGE (DLP).
VM-PROXY-01	**160**	**Linux (Nginx)**	Reverse Proxy, MyDLP	**Edge Guard.** Handles incoming SSL termination and outgoing DLP checks.
VM-HONEY-01	**160**	**Linux (T-Pot)**	Honeypot	**Deception.** Designed to be "found." Monitors for lateral movement in DMZ/Guest.

Risk Assessment & Security Control Matrix

Risk / Threat	Security Controls & Mitigation Measures
Misconfiguration	Implementation of **Infrastructure as Code (IaC)** and regular audits of **Standard Operating Procedures (SOP)**
Administrative & Operational Overhead	Employment of **specialized personnel**, continuous **training**, maintaining an **internal SOP Wiki**, and utilizing **standardized VM templates**.
Social Engineering & Phishing	Comprehensive **security awareness programs** and deployment of **FortiGate Mail Security** suites.
Shadow IT & Policy Non-Compliance	Continuous **security monitoring**, targeted **awareness training**, and strict **Egress Filtering** via the security stack.
Supply Chain & Third-Party Dependencies	Regular **vulnerability scanning**, proactive **patch management**, and the use of a dedicated **Patch Sandbox (VLAN 140)** for testing.
Cluster Split-Brain Scenarios	Implementation of **redundant heartbeat connections** and a dedicated **Quorum Device (Witness Server)** to maintain cluster integrity.
Credential Theft & Unauthorized Access	Mandatory **Multi-Factor Authentication (MFA)** for all administrative and sensitive access points (VLAN 20/150).
Ransomware Targeting Backup Integrity	Utilization of **Immutable Repositories** and **air-gapped backup** strategies to ensure data recoverability.